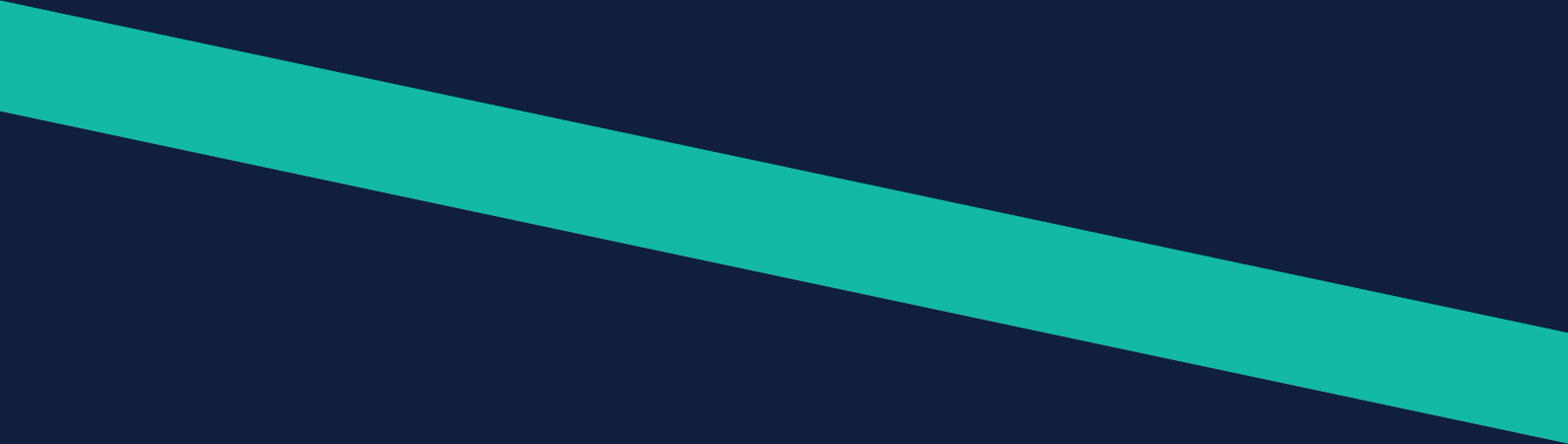




VILLA ACCESS CONTROL

AI система за управление на достъп до вили



Отчет за състоянието на проекта
Версия от 25 Май 2026

Production deployment: 6.5.4.254 • **Repo:** github.com/mladenovpeter-maker/VillaAccess



Какво представлява системата

Villa Access Control е AI-базирана платформа за автоматичен и контролиран достъп до вили, апартаменти и затворени комплекси. Системата обединява разпознаване на регистрационни номера (ANPR), smart ключалки, домофони, камери и резервационна система в едно работно място — без оператор на портала.

4 канала за достъп	24/7 автоматичен режим	3 роли (admin / operator / viewer)	BG локализиран UI
------------------------------	----------------------------------	---	-----------------------------

Кой ползва системата



Администратор

Управлява вили, устройства, потребители, резервации; вижда всичко, включително диагностика и event логове.



Оператор

Издава временни PIN кодове за гости, отваря врати ръчно при нужда, одобрява/отхвърля заявки за достъп от ANPR.



Наблюдател

Само за четене — събития, статус, история. Полезно за нощни смени, охрана, мениджъри.

Какво може системата

Основни модули

□ ANPR — разпознаване на регистрационни номера

Камери на портала автоматично четат номера на пристигащи коли. Системата ги сравнява с активни резервации и одобрени превозни средства, и автоматично отваря бариерата или вратата чрез релейна команда към интеркома.

Стек: YOLO + EasyOCR worker, fuzzy matching на номера, snapshot история на всяко четене.

□ Smart Locks (TuYa)

Управление на интелигентни ключалки през TuYa Cloud API. Издаване на временни PIN кодове за гости, които автоматично се синхронизират към ключалките за периода на резервацията и се изтриват след нея.

□ Домофони и Hikvision камери

Live статус, ISAPI диагностика, видео snapshots при event-и. Интегрирани Hikvision IP камери с пълна network диагностика (DNS, port, auth, device info).

□ Резервационна система

Управление на резервации с автоматично генериране на PIN кодове за периода на престоя, авто-изтичане, история и одит. Свързано с превозните средства на госта за автоматично ANPR одобрение.

□ Временни credentials

Бързо издаване на еднократен/ограничен във времето достъп — за куриери, техници, чистачи. Достъпно и от operator поля (без admin намеса).

□ Event timeline и одит

Всяко отваряне, всяко четене на номер, всяка ANPR грешка, всеки нов PIN — записано с timestamp и потребител. SSE live stream + REST история + статистика за последните 24 часа.

Архитектура и комуникация

Цялата комуникация с устройствата е изходяща (outbound) от backend-а. Камерите, домофоните и ключалките никога не звънят на сървъра — той ги пита периодично. Това позволява максимално затваряне на портове без да се наруши работата.

Backend Node.js + Express	→	Hikvision камери ISAPI / HTTP
Backend	→	Tuya Cloud openapi.tuya.eu.com
Backend	→	Домофони HTTP relay команди
ANPR Worker YOLO + EasyOCR	→	Backend Docker internal net
Frontend (nginx) SPA + /api proxy	→	Backend Docker internal net
Потребител (браузър)	→	Frontend (порт 3000) единствена публична точка

Технологичен стек

Frontend	React 18 + Vite + TypeScript + TailwindCSS + Radix UI
Backend	Node.js + Express 5 + TypeScript + Drizzle ORM
База данни	PostgreSQL 16
AI / ANPR	Python worker — YOLO детекция + EasyOCR четене
Deployment	Docker Compose, self-hosted на 6.5.4.254
Monorepo	pnpm workspaces — dashboard / api-server / db / api-zod

Какво сме свършили наскоро

Последна сесия работа — само additive, нула пипане по критичните потоци (OCR/YOLO, релета, snapshot, резервации, Hikvision, fuzzy gating).

087a5
0d

i18n корекция

Поправен typo в bg.ts; добавени преводи за health uptime съобщенията.

135cd
e5

Operator достъп до временни credentials

API endpoint adminOnly → writeAccess; App.tsx route opOrAbove; sidebar item видим за operator.

570b9
4c

Мобилен POC — layout + controls

app-layout с responsive header (pl-16 md:pl-6) и адаптивни paddings; премахнат вложен p-6 в controls.tsx.

f56b6c
1

Мобилно — останалите 5 страници

Reservations, vehicles, temp-credentials: dialogs w-[95vw] max-h-[90vh], grid-cols-1 sm:grid-cols-N, vehicles tiles 2 col на мобилен / 3 на desktop, stats bar flex-wrap, селекторите w-full на mobile.

c5ff32
d

☐ Security hardening (B+C+D+F+G)

Helmet headers, rate-limit на /auth/login (10/15мин) и /auth/refresh (60/15мин), env-driven CORS allowlist, trust proxy, затворени Docker хост портове (postgres + backend → expose), qs CVE-2026-8723 fix, warning при липсващ JWT_SECRET в production.

Сигурност — текущо състояние

Какво вече е защитено

- ✓ Security headers (Helmet) — X-Frame-Options, XSS, HSTS, Referrer-Policy, COOP, nosniff
- ✓ Brute-force защита — rate-limit на login (10 опита / 15 мин на IP) и refresh (60 / 15 мин)
- ✓ CORS allowlist — env-driven (CORS_ALLOWED_ORIGINS), backwards compatible
- ✓ Затворени Docker портове — postgres (5432) и backend (8080) вече само вътре в compose мрежата
- ✓ qs CVE-2026-8723 — fix чрез pnpm override към 6.15.2
- ✓ JWT secret warning — loud log в production ако се ползва dev fallback
- ✓ Refresh token ротация — 15 мин access, 7 дни refresh, DB-проследен
- ✓ Zod валидация на всички auth endpoints
- ✓ Role-based access — adminOnly за смяна на устройства; operator само за гост-достъп

Какво остава в backlog

- A HTTPS / TLS на nginx — изисква решение за сертификат (Let's Encrypt vs self-signed). Без HTTPS паролите летят в чист вид при достъп извън LAN.
- E bcrypt пароли — в момента SHA-256 със сол. При изтекла база е счупимо. Препоръка: dual-hash миграция (нови = bcrypt, стари автоматично пресмятат при login).
- ? 2FA / Google Authenticator — отложено по заявка на потребителя. Може да се добави opt-in за admin роля без UX тежест за оператори.

Deployment и експлоатация

6.5.4.2 54 production host	:3000 единствен публичен порт	main GitHub branch	auto-push след всеки task
---	---	--	---

Deploy flow

Стандартен deploy цикъл

```
git pull
docker compose down
docker compose up -d --build
```

Миграциите се пускат автоматично от migrate сервиса преди backend-a. .env.docker файлът (symlink към .env) държи всички тайни.

Какво следва (предложения)

□ Приоритет 1	Включване на HTTPS в nginx (commented HTTPS block + Let's Encrypt). Това е най-голямата дупка останала.
□ Приоритет 2	Миграция на пароли към bcrypt с dual-hash стратегия. Защи́тава ако базата изтече.
□ Приоритет 3	2FA за admin — opt-in TOTP. Лесна добавка, голяма стойност за главния акаунт.
□ Идея	Мобилно PWA wrapping — операторите вече имат responsive UI; install-on-home-screen ще даде native-like преживяване.
□ Идея	Push notifications за критични events (отворена врата извън часовете, нова ANPR неразпозната кола, неуспешен PIN x пъти).

Този отчет е генериран автоматично от Replit Agent на база реалното състояние на git хранилището. За въпроси и следващи стъпки — просто пиши в чата.